Segurança da Solução

Visão Geral

A solução foi projetada seguindo o princípio de defesa em profundidade (Defense in Depth), aplicando múltiplas camadas de segurança desde a borda até os serviços internos.

O objetivo é garantir:

- autenticação segura de usuários
- autorização consistente
- proteção contra ataques comuns
- isolamento entre serviços
- proteção de dados sensíveis

A arquitetura utiliza serviços gerenciados da AWS para reduzir a superfície de ataque e aumentar a confiabilidade da segurança.

---

1. Autenticação

A autenticação é realizada por meio de um Identity Provider (IdP), como o Amazon Cognito, utilizando o padrão OAuth2 / OpenID Connect.

Fluxo de autenticação:

1. O usuário acessa a aplicação web hospedada em S3 via CloudFront
2. É redirecionado para o provedor de identidade (Cognito)
3. Realiza login com credenciais válidas
4. Recebe um Access Token (JWT)
5. O token é enviado em todas as requisições para a API:

Authorization: Bearer <JWT>

Benefícios:

- separação entre autenticação e aplicação
- suporte a SSO e múltiplos provedores
- tokens stateless, sem necessidade de sessão no backend

---

2. Autorização

A autorização é aplicada em duas camadas:

API Gateway

- valida assinatura e expiração do JWT
- valida permissões através de claims/scopes
- bloqueia requisições não autorizadas antes de atingir o backend

Serviços de backend

- podem aplicar regras adicionais de autorização (ex: perfil do usuário)

Benefícios:

- modelo fail-fast (bloqueio antecipado)
- redução de carga nos serviços internos
- controle centralizado de acesso

---

3. Proteção de APIs

A proteção da API é realizada em múltiplas camadas:

CloudFront (Edge Layer)

- atua como ponto de entrada global
- reduz exposição direta da API
- melhora performance e latência

AWS WAF (Web Application Firewall)

O WAF atua na camada de aplicação (L7), inspecionando todas as requisições HTTP.

Proteções aplicadas:

- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- ataques baseados em payload malicioso
- bots e tráfego automatizado

Funcionamento:

- integrado ao CloudFront

- avalia cada requisição antes de chegar à API
- bloqueia automaticamente requisições maliciosas

Benefícios:

- proteção proativa contra vulnerabilidades conhecidas
- redução da superfície de ataque
- atualização dinâmica de regras sem necessidade de deploy

AWS Shield (Proteção contra DDoS)

O AWS Shield protege contra ataques de negação de serviço (DDoS).

Tipos de ataques mitigados:

- HTTP floods
- SYN floods
- ataques volumétricos (camadas 3 e 4)

Funcionamento:

- integrado automaticamente ao CloudFront
- detecta tráfego anômalo
- aplica mitigação automática

Benefícios:

- garante alta disponibilidade
- proteção automática sem necessidade de configuração adicional
- absorção de picos maliciosos de tráfego

API Gateway

- valida tokens JWT
- aplica throttling e rate limiting
- valida estrutura das requisições

---

4. Rate Limiting

O rate limiting é implementado no API Gateway para controlar o volume de requisições aceitas.

Funcionamento:

- define limites de requisições por segundo
- controla bursts de tráfego

Exemplo:

100 requisições por segundo com burst de 200

Benefícios:

- evita sobrecarga do sistema
- protege contra abuso e ataques automatizados
- mantém estabilidade sob carga

Justificativa:

Mesmo com uso de filas (SQS), o rate limiting protege a camada de entrada, impedindo que o sistema seja inundado por requisições maliciosas.

---

5. Proteção de Dados Sensíveis

Os dados são protegidos em todas as camadas:

Banco de dados (RDS)

- criptografia em repouso habilitada
- acesso restrito via Security Groups e IAM

Data Mesh (S3)

- buckets privados
- acesso controlado via políticas IAM
- sem exposição pública

Logs

- dados sensíveis não são armazenados em logs
- tokens e informações críticas são mascarados

Benefícios:

- redução de risco de vazamento
- aderência a boas práticas de segurança

---

6. Estratégia de Criptografia

Em trânsito

- comunicação via HTTPS (TLS 1.2 ou superior)
- proteção contra interceptação

Em repouso

- RDS criptografado via KMS
- SQS criptografado via KMS
- S3 criptografado via KMS

Gerenciamento de chaves

- centralizado no AWS KMS
- possibilidade de rotação automática

---

7. Controle de Acesso entre Serviços

O acesso entre serviços é controlado por IAM Roles, sem uso de credenciais fixas.

Serviço de Lançamentos (API)

- permissão para enviar mensagens ao SQS

Worker Consolidado

- permissão para consumir mensagens do SQS
- permissão para persistir dados no RDS
- permissão para escrever no Data Mesh

Princípios adotados:

- least privilege (menor privilégio possível)
- credenciais temporárias via STS (implícito)
- isolamento entre serviços

---

8. Idempotência

A idempotência garante que o processamento de mensagens duplicadas não cause efeitos indesejados.

Contexto:

O SQS opera com modelo at-least-once delivery, podendo entregar a mesma mensagem mais de uma vez.

Solução:

- cada evento possui um identificador único (eventId)
- antes de persistir, o sistema verifica se o evento já foi processado

Estratégias:

- chave única no banco
- controle de eventos processados
- validação por hash

Benefícios:

- evita duplicidade de lançamentos
- garante consistência dos dados
- permite retry seguro

---

9. Retry e Dead Letter Queue (DLQ)

Funcionamento:

- mensagens com falha são reprocessadas automaticamente
- após número máximo de tentativas, são enviadas para a DLQ

Benefícios:

- evita perda de dados
- permite reprocessamento posterior
- isola mensagens problemáticas

---

10. Monitoramento e Auditoria

A solução utiliza o CloudWatch para observabilidade:

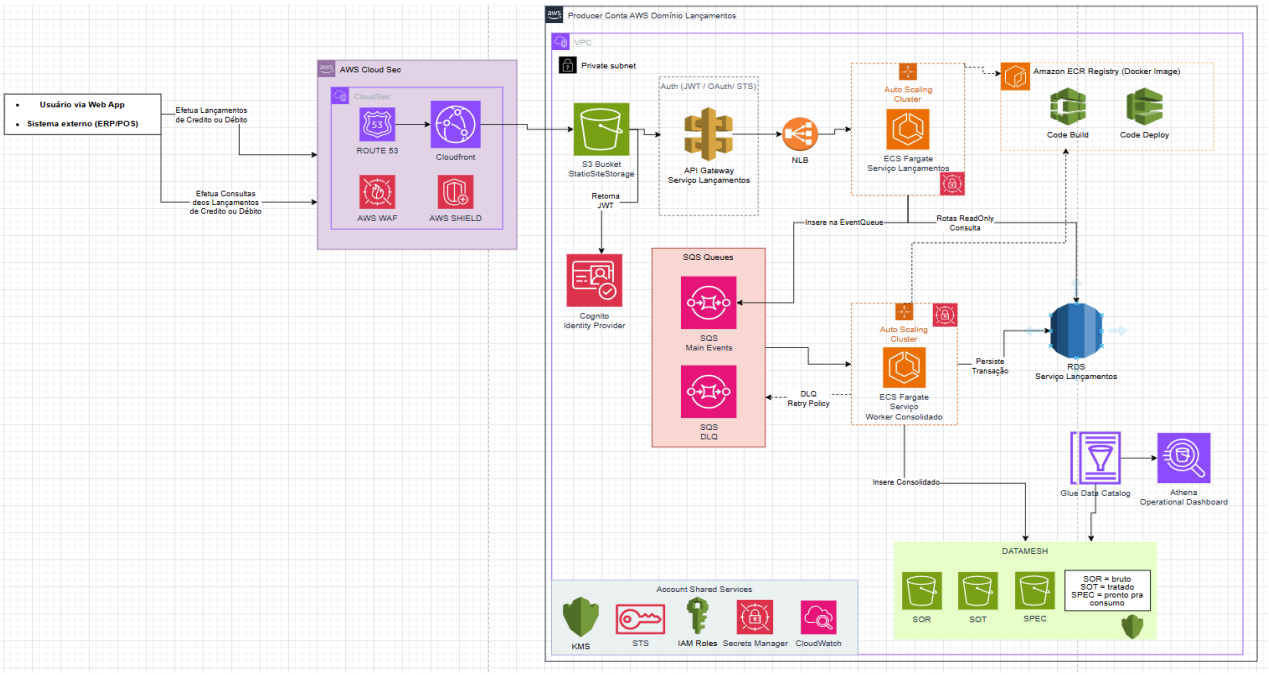
- logs estruturados
- métricas de consumo e erro
- alarmes automáticos

Benefícios:

- detecção rápida de falhas
- rastreabilidade
- suporte à auditoria

Conclusão

A arquitetura implementa múltiplas camadas de segurança, combinando autenticação baseada em JWT, autorização centralizada, proteção de borda com WAF e Shield, controle de acesso via IAM, criptografia em trânsito e em repouso, e mecanismos de resiliência como idempotência e DLQ.

Essa abordagem reduz a superfície de ataque, aumenta a confiabilidade da solução e garante aderência às boas práticas de segurança em ambientes cloud.

Desenho de Arquitetura + Segurança: